THREAT MODEL & SECURITY REQUIREMENTS

Secure Messaging & Signed Document System | Team ZeroDay

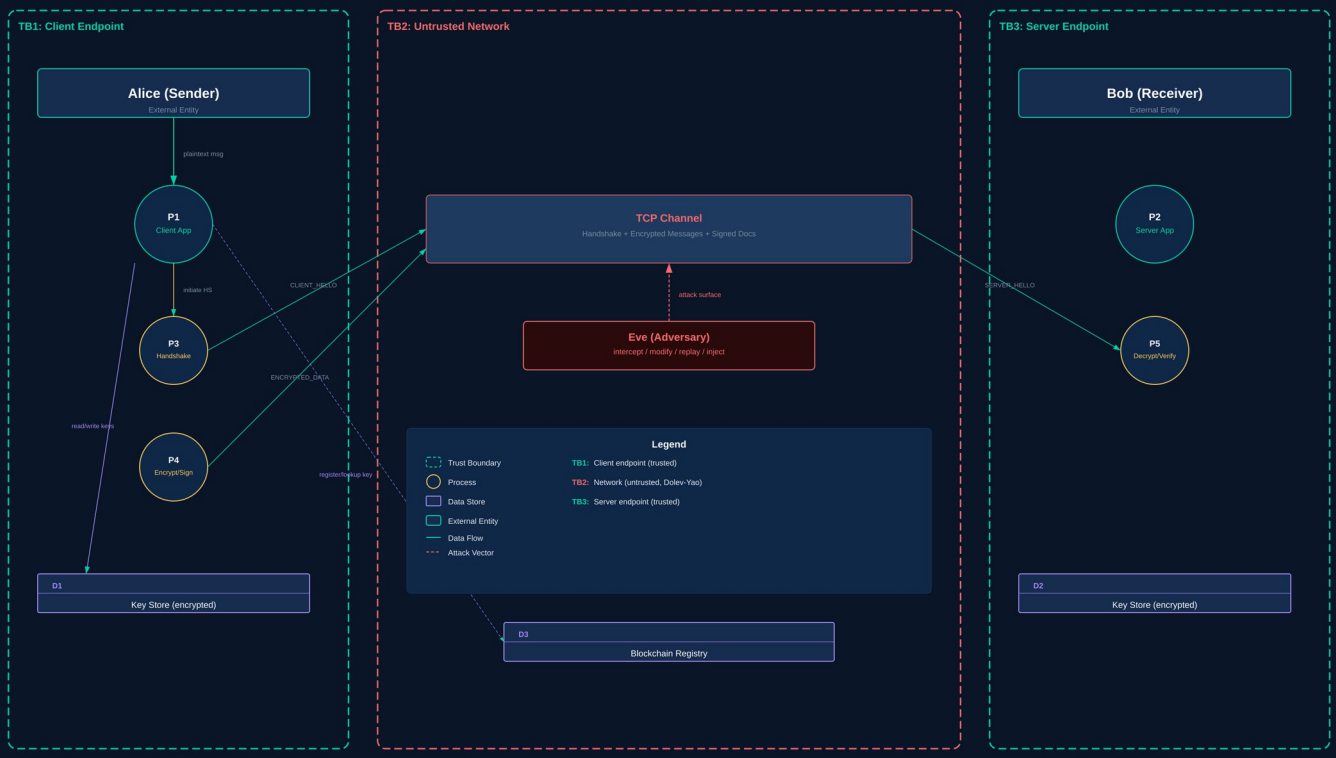
1. Threat Model Overview

Adversary model: Dolev-Yao — the adversary controls the network. They can intercept, modify, replay, drop, and inject messages on the wire. They cannot access endpoint memory or private keys unless a key compromise scenario is explicitly triggered.

Assets: Message plaintext, session keys, long-term identity keys, document contents, user identity bindings, blockchain key registry integrity.

Trust boundaries: TB1 (Client endpoint — trusted), TB2 (Network — untrusted, adversary-controlled), TB3 (Server endpoint — trusted). All data crossing TB1→TB2 or TB2→TB3 must be encrypted and authenticated.

1.1 Data Flow Diagram



Key flows crossing trust boundaries: CLIENT_HELLO (P3→TB2), SERVER_HELLO (TB2→P5), ENCRYPTED_DATA (P4→TB2→P5), SIGNED_DOCUMENT (P4→TB2→P5), blockchain queries (P1→D3). Every flow crossing TB2 is the attack surface.

2. Security Requirements (≥10 Testable "Shall" Statements)

ID	Requirement	Test Method
SR-01	The system SHALL perform authenticated key exchange using X25519 with Ed25519-signed ephemeral public keys before any message encryption.	Handshake unit test: verify signature on exchanged keys; reject unsigned keys.
SR-02	The system SHALL derive session keys using HKDF-SHA256 with a protocol-specific salt and domain-separated info strings; raw DH output SHALL NOT be used as an encryption key.	Unit test: assert derived key differs from raw DH output; assert key/nonce are independent.
SR-03	The system SHALL encrypt all message payloads using AES-256-GCM with AAD binding the header (version, type, session_id, seq).	Wireshark capture test: verify no plaintext on wire. AAD modification test: verify decryption fails.
SR-04	The system SHALL reject any message with a sequence number less than or equal to the last accepted sequence number.	Replay test: send msg with seq=5 twice; second is dropped with ERR_SEQ_REPLAY.
SR-05	The system SHALL verify Ed25519 signatures on all handshake messages and reject any message where verification fails with ERR_SIG_INVALID.	MITM test: inject rogue public key; verify handshake aborts.
SR-06	The system SHALL construct AES-GCM nonces as base_nonce XOR seq and SHALL NOT expose a manual nonce parameter.	API test: confirm encrypt() has no nonce arg. Uniqueness test: 10k msgs produce 10k unique nonces.
SR-07	The system SHALL zero ephemeral X25519 private keys and raw shared secrets from memory immediately after HKDF derivation.	Memory inspection test: dump process memory after handshake; grep for known key pattern returns zero matches.
SR-08	The system SHALL reject ciphertext where the GCM authentication tag does not verify, returning ERR_TAG_INVALID.	Tamper test: flip one byte in ciphertext; verify InvalidTag raised and message dropped.
SR-09	The system SHALL sign documents using Ed25519 over the SHA-256 hash and SHALL verify signatures before accepting any received document.	Doc signing roundtrip: sign, modify 1 byte in doc, verify returns False.
SR-10	The system SHALL register Ed25519 public keys on the blockchain and SHALL reject handshakes with keys not present on-chain or marked REVOKED.	Registration test: register key, query chain, assert match. Revocation test: revoke key, attempt handshake, verify ERR_KEY_REVOKED.
SR-11	The system SHALL terminate sessions exceeding 24 hours or 2^32 messages and require a new handshake with fresh ephemeral keys.	Session expiry test: mock clock forward 24h; verify ERR_SESSION_EXPIRED and automatic rekey.
SR-12	The system SHALL send a signed CLOSE_NOTIFY message before closing a connection to prevent silent truncation by an adversary.	Truncation test: close without CLOSE_NOTIFY; verify receiver logs a warning. With CLOSE_NOTIFY: clean shutdown.

3. Misuse Cases (≥6)

Each misuse case describes a realistic attack, the vulnerable component, and the specific defense.

MC	Attack	Scenario	Consequence if Unmitigated	Defense
MC1	Replay attack	Eve captures a valid ENCRYPTED_DATA message (seq=42) and retransmits it 5 minutes later to trigger duplicate action (e.g., double payment).	Receiver processes duplicate; application-level damage (double execution).	Monotonic seq counter rejects seq ≤ last_seen (SR-04). ERR_SEQ_REPLAY logged.
MC2	Nonce reuse	A buggy implementation reuses the same GCM nonce for two messages under the same session key, leaking the GHASH authentication key.	Adversary recovers auth key, forges ciphertext that passes GCM verification; full confidentiality and integrity loss.	Nonce = base_nonce XOR seq (SR-06). Counter auto-increments. Hard rekey at 2^32. No manual nonce API.
MC3	MITM key substitution	Eve intercepts CLIENT_HELLO, replaces client_ephemeral_pk with her own key, forwards to server. She now shares a secret with both parties.	Eve decrypts all traffic in both directions. Full compromise of confidentiality, integrity, authentication.	Ed25519 signature on every ephemeral key (SR-05). Signature binds key to long-term identity. ERR_SIG_INVALID aborts handshake.
MC4	Ciphertext tampering	Eve modifies bytes in an ENCRYPTED_DATA message in transit, hoping to corrupt the plaintext or cause a processing error.	If no integrity check: receiver decrypts corrupted plaintext; possible injection of malicious content.	GCM auth tag detects any modification (SR-08). ERR_TAG_INVALID; message dropped entirely.
MC5	Key leakage from memory	Attacker with partial memory access (core dump, swap file) reads ephemeral private key or session key that was not zeroed after use.	Attacker decrypts the current session; if long-term key leaked, can impersonate user in future sessions.	Ephemeral keys zeroed after HKDF (SR-07). Session keys in non-serializable wrapper. Forward secrecy limits blast radius.
MC6	Downgrade to weaker cipher	Eve modifies CLIENT_HELLO to remove AES-256-GCM from supported_ciphers, forcing fallback to a weaker algorithm (if one existed).	Weaker cipher may have known vulnerabilities; adversary exploits them to break confidentiality.	Only AES-256-GCM is supported. ERR_CIPHER_MISMATCH if list is empty. Cipher selection in SERVER_HELLO is signed (SR-05), so Eve cannot modify it undetected.
MC7	Session truncation	Eve silently drops the TCP connection mid-conversation, preventing Alice from sending a critical final message to Bob.	Bob doesn't know the conversation was cut short; may act on incomplete information.	Signed CLOSE_NOTIFY required for clean shutdown (SR-12). Heartbeat timeout detects silent drops within 10s.
MC8	Document signature forgery	Eve creates a fake document, computes its SHA-256 hash, and attempts to forge an Ed25519 signature matching Alice's public key.	If forgery succeeds: Eve can attribute fake documents to Alice; non-repudiation is broken.	Ed25519 provides 128-bit security (SR-09). Forgery requires ~2^128 operations. Blockchain timestamps prove signing time.

4. Traceability: Threats → Requirements → Misuse Cases

Every threat maps to at least one security requirement and is exercised by at least one misuse case.

ID	Threat	Security Requirements	Misuse Cases	Primitives Involved
T1	Passive eavesdropping	SR-01, SR-02, SR-03	MC3 (partial)	X25519, HKDF, AES-256-GCM
T2	MITM key substitution	SR-01, SR-05, SR-10	MC3	Ed25519, Blockchain
T3	Ciphertext tampering	SR-03, SR-08	MC4	AES-256-GCM (auth tag)
T4	Replay attack	SR-04, SR-06	MC1	Seq numbers, nonce construction
T5	Signature forgery	SR-05, SR-09	MC8	Ed25519, SHA-256
T6	Session truncation	SR-12	MC7	CLOSE_NOTIFY, heartbeat
T7	Key compromise	SR-07, SR-10, SR-11	MC5	X25519 (forward secrecy), REVOKE
T8	Document repudiation	SR-09, SR-10	MC8	Ed25519, SHA-256, blockchain
T9	Nonce reuse	SR-06, SR-11	MC2	AES-GCM nonce construction
T10	Cipher downgrade	SR-05	MC6	Signed cipher negotiation

Coverage summary: 10 threats mapped to 12 security requirements and 8 misuse cases. Every requirement traces to at least one threat. Every misuse case exercises at least one requirement. No orphaned requirements or untested threats.